

Producción de Software

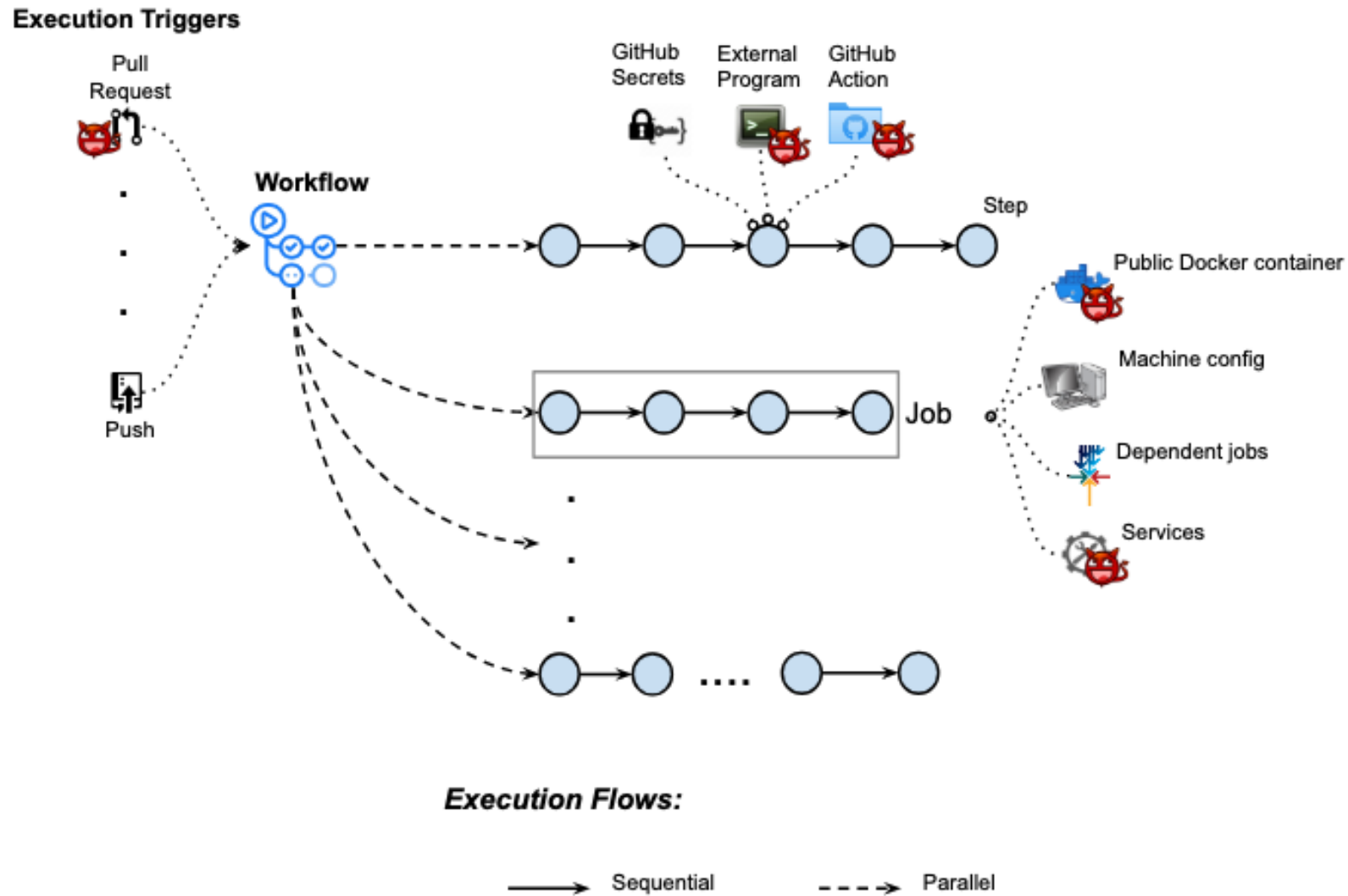
Pablo Valenzuela

4 Mayo 2026

Characterizing the Security of Github CI Workflows

1. **RQ1:** ¿Cuáles son las propiedades de seguridad que deben cumplirse para tener un CI/CD seguro?
2. **RQ2:** ¿Cómo se compara GitHub CI con otras plataformas CI/CD respecto a estas propiedades de seguridad?
3. **RQ3:** ¿Cómo el uso de workflows por parte de los desarrolladores afecta estas propiedades de seguridad?

Dónde está el problema



Dónde está el problema

```
name: MyWorkflow      ← Workflow Name

on: ← Execution Triggers
  # Workflow triggers on push
  # and pull requests to the main branch
push:
  branches: [ main ]
pull_request:
  branches: [ main ]
  # Also, workflow gets executed every day at 5 am UTC
schedule:
  - cron: "0 5 * * *"

jobs: ← All Jobs in the Workflow

build: ← Job (Name: Build)

  runs-on: ubuntu-latest ← Job's Machine configuration

  steps: ← All Steps in the Job
    # The following steps are executed sequentially

    # Check out the current repository
    # on default branch
    - name: Checkout the repository ①
      uses: actions/checkout@v2

    # Execute the given command using shell
    - name: Build Project ②
      run: sudo ./build.sh
```

```
  # Execute action defined in the current repository
- name: Local Action ③
  uses: ../path/to/action@v2
  with:
    apikey: ${secrets.API_KEY} 🔒

  # Perform static analysis of all source files
  # in the repository using an action from
  # its public GitHub URL.
- uses: microsoft/devskim-action@45bc8e9 ④
  with:
    directory-to-scan: .
    output-directory: scanneroutput

test: ← Job (Name: Test)

  needs: build ← Dependent jobs
  runs-on: ubuntu-latest

  steps:
    - name: Test Project ⑤
      run: sudo ./test.sh
```

RQ1: ¿Cuáles son las propiedades de seguridad que deben cumplirse para tener un CI/CD seguro?

Un sistema CI/CD seguro debe cumplir cuatro propiedades clave:

- controlar quién puede modificar workflows,
- cómo se ejecutan,
- qué código se ejecuta, y
- cómo se accede a los secretos

RQ2: ¿Cómo se compara GitHub CI con otras plataformas CI/CD respecto a estas propiedades de seguridad?

		TravisCI	CircleCI	Jenkins	Gitlab CI external	Gitlab CI internal	Github CI
Admittance Control	(C1) Contributor can add workflow	●	●	●	●	●	●
	(C2) CI/CD run can NOT add new workflow	●	●	○	●	●	○ ^W
	(C3) Executes workflow from PR only after merge	●	● ^I	○	●	● ^I	● ^I ^W
Execution Control	(C4) Contributors can modify the triggers	●	●	●	●	●	●
	(C5) CI/CD run can NOT modify the triggers	●	●	○	●	●	○ ^W
Code Control	(C6) CI/CD run can NOT modify the code	●	●	○	●	●	○ ^W
	(C7) CI/CD run is deterministic based on config	●	●	●	●	●	○ ^W
Access to Secrets	(C8) Masked	●	●	● ^I	●	●	●
	(C9) Accessible only to explicitly authorized steps	○	○	● ^I	●	●	○
	(C10) Restricted from pull requests	●	● ^I	● ^I	●	● ^I	● ^I ^W

Table 3: Comparison of five different CI/CD platforms in four security properties (AC, EC, CC, AS). Open circle (○) - means no. Filled circle (●) - means yes. Half circle (◐) - means developers can configure the feature in config file or by using plugin. The shades of red indicate conditions violating the security property in corresponding platforms. The marker W indicates whether the condition is workflow or configuration dependent.

RQ3: ¿Cómo el uso de workflows por parte de los desarrolladores afecta estas propiedades de seguridad?

Los resultados muestran que el comportamiento de uso de los workflows afecta directamente la seguridad, evidenciando prácticas comunes como sobreprivilegios, uso de acciones no verificadas y referencias mutables que incrementan la superficie de ataque.

Implicancias

- La seguridad de los workflows depende fuertemente de las decisiones de configuración de los desarrolladores, no solo de la plataforma.

Implicancias

- La seguridad de los workflows depende fuertemente de las decisiones de configuración de los desarrolladores, no solo de la plataforma.
- El uso de acciones de terceros y referencias mutables introduce riesgos sistémicos en la supply chain del CI/CD.

Implicancias

- La seguridad de los workflows depende fuertemente de las decisiones de configuración de los desarrolladores, no solo de la plataforma.
- El uso de acciones de terceros y referencias mutables introduce riesgos sistémicos en la supply chain del CI/CD.
- Es necesario desarrollar herramientas y guías que ayuden a detectar y corregir automáticamente malas prácticas en workflows.

Characterizing the Security of Github CI Workflows

- La seguridad en GitHub Actions no es solo un problema de la plataforma, sino del uso que los desarrolladores hacen de ella:
 - los sistemas CI/CD requieren propiedades de seguridad claras (RQ1),
 - pero GitHub CI no las cumple consistentemente frente a otras plataformas (RQ2),
 - pero GitHub CI no las cumple consistentemente frente a otras plataformas (RQ3),
- Entonces, si confías solo en la plataforma sin revisar cómo se configuran y usan los workflows, estás ignorando el principal origen de vulnerabilidades en CI/CD

Referencias

- Koishybayev, I., Nahapetyan, A., Zachariah, R., Muralee, S., Reaves, B., Kapravelos, A., & Machiry, A. (2022). Characterizing the security of github {CI} workflows. In *31st USENIX Security Symposium (USENIX Security 22)* (pp. 2747-2763).